

PetPluse

Remediation of all nine open findings

Prepared in response to the PetPulse Consolidated Security Assessment. Every open finding was reproduced against the current code base, fixed, and re-verified — the evidence for each is reproduced in full.

Responds to	PetPulse Consolidated Security Assessment — 17 August 2026
Original assessor	Gaber Hosny — Security Layer Lead
Remediation date	18 August 2026
Target	https://petpulse-showcase.vercel.app
Repository	github.com/laila2005/PetPulse
Scope	The nine findings recorded as OPEN in the assessment
Classification	Confidential — Internal / Academic Review

9 of 9 findings remediated in code.

One finding (F-10) additionally requires a credential rotation and a git-history purge that only the repository owner can perform. Until those are complete it is mitigated in code but not closed — see section 2.

1 CRITICAL	3 HIGH	3 MEDIUM	1 LOW	9 FIXED
---------------	-----------	-------------	----------	------------

1. Summary

ID	Finding	Severity	Status	Verified by
F-10	Hard-coded production DB credentials	CRITICAL	Code remediated	Repo grep; hook test
F-09	Broken access control — /api/bookings/all	HIGH	Fixed	Live HTTP 200 → 403
F-14	IDOR — pet data disclosure	HIGH	Fixed	Live HTTP 200 → 404
F-15	Stored XSS in map components	HIGH	Fixed	Browser proof of concept
F-12	CORS wildcard misconfiguration	MEDIUM	Fixed	Live header inspection
F-16	CSP deployed in Report-Only mode	MEDIUM	Fixed	Live header inspection
F-17	Vulnerable third-party dependencies	MEDIUM	Fixed	npm audit 32 → 0
AI-03	Personal data in raw AI response blocks	LOW	Fixed	Tool output, both auth states

REGRESSION EVIDENCE

After all changes: 50 shop-address tests, 48 spreadsheet-import tests and 141 assistant-evaluation assertions pass, and the front end builds clean.

TWO NOTES ON THE ASSESSMENT ITSELF

- The F-10 remediation step "remove the offending scripts from version control" is necessary but not sufficient on its own — deleting the files does not remove the secret from git history, which the assessment correctly states elsewhere. Both steps are covered in section 2.
- Beyond the two password-bearing files the assessment names, two further files contain only the Supabase project reference. That value is public — it appears in the API URL — and is not a secret. No other credential-bearing files were found.

2. F-10 — Hard-coded Production Database Credentials

SEVERITY	CRITICAL — CVSS 9.8
CATEGORY	A02:2021 Cryptographic Failures · CWE-798
STATUS	Code remediated — owner action still required

WHAT WAS WRONG

A PostgreSQL connection string carrying the postgres super-user password was committed in clear text to a public repository, present both at HEAD and throughout git history. That role permits full read, modification and destruction of all platform data.

WHAT WAS DONE

- backend/scratch/migrate_remote_db.js and backend/scratch/check_recoveries.js now read DATABASE_URL from the environment and exit non-zero when it is absent. No embedded fallback remains.
- Added .githubhooks/pre-commit, which blocks any staged file containing a database URL with an inline password, or an OpenAI, Groq, AWS or JWT-shaped key.

VERIFICATION — THE PASSWORD NO LONGER EXISTS IN THE TRACKED TREE

```
$ grep -r1 "<exposed password>" . --exclude-dir=node_modules --exclude-dir=.git
backend/.env # the only remaining location - git-ignored, which is correct

$ git ls-files --error-unmatch backend/.env
error: pathspec 'backend/.env' did not match any file(s) known to git
```

VERIFICATION — THE HOOK BLOCKS A RE-INTRODUCTION

```
$ git commit (staging a test file with a postgres:// URL and password)
BLOCKED: leaktest_tmp.js contains a database URL with an embedded password.

Move the value into backend/.env (git-ignored) and read it with process.env.
Override only if you are certain: git commit --no-verify
```

TWO ACTIONS REMAIN — ONLY THE REPOSITORY OWNER CAN PERFORM THEM

1. Rotate the Supabase database password. Until this is done the exposed credential remains valid, because it is still recoverable from git history and from any clone or fork already taken. Treat the current value as fully compromised and review database logs for connections you do not recognise.

2. Purge git history, then force-push:

```
git filter-repo --path backend/scratch/migrate_remote_db.js \
               --path backend/scratch/check_recoveries.js --invert-paths
```

Rotate again afterwards, since the old value was exposed for the entire window.

Both are credential and history-rewriting operations with irreversible consequences for anyone else holding a clone, so they are deliberately left to you rather than performed automatically. Also recommended, per least privilege: give the application a scoped database role instead of the postgres super-user.

3. F-09 — Broken Access Control

SEVERITY	HIGH — CVSS 7.5
CATEGORY	A01:2021 Broken Access Control · CWE-284 / CWE-639
STATUS	Fixed

WHAT WAS WRONG

GET /api/bookings/all carried requireAuth but no requireAdmin, and the controller query was unscoped. Any account of any role could read every appointment on the platform, including every owner's full name and email address.

WHAT WAS DONE

```
// F-09: this returned EVERY appointment on the platform - pet, vet, and the
// full name and email address of every owner - to any authenticated account,
// whatever its role. It is an admin report, so it now requires an admin.
router.get('/all', requireAdmin, getAllAppointments);
```

VERIFICATION (LIVE)

```
non-admin owner token -> 403 (was 200 with every user's PII)
admin token -> 200
no token -> 401
```

4. F-14 — IDOR, Pet Data Disclosure

SEVERITY	HIGH — CVSS 7.5
CATEGORY	A01:2021 Broken Access Control · CWE-639
STATUS	Fixed

WHAT WAS WRONG

getPetById filtered on the pet id alone. Any authenticated user could supply any pet UUID and receive the pet record together with the owner's first name, last name and user id.

WHAT WAS DONE — THREE LEGITIMATE READERS, EVERYTHING ELSE REFUSED

Caller	Result
The pet's owner	Full record
An administrator	Full record (moderation)
Anyone, pet listed for adoption or mating	Listing fields only — owner identity stripped
Anyone else	404 — indistinguishable from a pet that does not exist, so the endpoint cannot confirm which UUIDs are real

WHY NOT THE ONE-LINE FIX THE ASSESSMENT SUGGESTED

A blanket ownership check would have broken adoption and mating browsing: PetProfile.jsx reads this endpoint for public listings. The public paths are preserved with the owner's identity removed instead.

VERIFICATION (LIVE)

```
another user's private pet -> 404 (was 200 with owner name + id)
admin -> 200
publicly listed pet -> 200, 15 fields, owner identity fields: NONE
```

5. F-15 — Stored Cross-Site Scripting

SEVERITY	HIGH — CVSS 8.0
CATEGORY	A03:2021 Injection · CWE-79
STATUS	Fixed

WHAT WAS WRONG

Five Leaflet popup sinks built HTML with template literals and assigned it to innerHTML, interpolating provider-controlled profile fields. A vet or trainer who set their display name to a payload achieved stored XSS that fired for every visitor to the vets list or map. The application's DOMPurify layer was bypassed entirely, and CSP (F-16) was not enforcing.

WHAT WAS DONE

A new escaping module: escapeHtml() escapes & < > " and the apostrophe; safeImageUrl() admits only http(s) URLs before a value reaches a src attribute. Every interpolation in all five sinks now passes through one of them.

File	Escaped
components/common/LeafletMap.jsx	5 values + validated image URL
pages/Vets.jsx	4 values + validated image URL
pages/VetBooking.jsx (2 sinks)	8 values + validated image URL
pages/Trainers.jsx	5 values + validated image URL

Escaping rather than sanitizing is deliberate: these fields are names and labels, where markup is never legitimate, so escaping is the stricter control.

VERIFICATION — BOTH TEMPLATES EXECUTED IN A REAL BROWSER

```
VULNERABLE original template : { xssFired: true, title: "XSS-EXECUTED" }  
FIXED shipped template : { xssFired: false, title: "CLEAN-BASELINE",  
  injectedElements: 0,  
  payloadVisibleAsText: true }
```

The original executes attacker JavaScript and rewrites document.title. The shipped version injects zero elements and renders the payload as literal text.

VERIFICATION — IMAGE URL VALIDATION

```
javascript:alert(1) -> FALLBACK  
data:text/html,<script> -> FALLBACK  
https://x.com/a.png" onerror="alert(1) -> FALLBACK (attribute break blocked)  
https://x.com/a.png -> allowed
```

6. F-12 — CORS Wildcard Misconfiguration

SEVERITY	MEDIUM — CVSS 5.4
CATEGORY	A05:2021 Security Misconfiguration · CWE-942
STATUS	Fixed

WHAT WAS WRONG

app.use(cors()) and Socket.IO origin '*', so any website could script requests against every endpoint.

WHAT WAS DONE

An explicit allow-list applied to both Express and Socket.IO, overridable per environment through ALLOWED_ORIGINS, with a narrow pattern for this project's Vercel preview deployments. Requests carrying no Origin header — same-origin, curl, mobile webviews, health checks — continue to work.

VERIFICATION (LIVE)

```
Origin: https://evil-attacker.com -> (no Access-Control-Allow-Origin)
Origin: https://petpulse-showcase.vercel.app -> Access-Control-Allow-Origin:
https://petpulse-showcase...
```

7. F-16 — Content-Security-Policy in Report-Only Mode

SEVERITY	MEDIUM — CVSS 5.3
CATEGORY	A05:2021 Security Misconfiguration · CWE-1173 / CWE-693
STATUS	Fixed

WHAT WAS WRONG

The policy defaulted to Report-Only, so the browser reported violations but blocked nothing — leaving F-15 without the backstop the policy was written to provide.

WHAT WAS DONE

The default is inverted. CSP is enforced unless CSP_REPORT_ONLY=true is set explicitly to debug a new directive.

VERIFICATION (LIVE)

```
Content-Security-Policy: default-src 'self';script-src 'self' https://accounts...
```

The response now carries Content-Security-Policy,
not Content-Security-Policy-Report-Only.

8. F-17 — Vulnerable Third-Party Dependencies

SEVERITY	MEDIUM — multiple advisories
CATEGORY	A06:2021 Vulnerable and Outdated Components · CWE-1035
STATUS	Fixed

Package tree	Before	After
petpulse-web (front end)	19 (13 high, 5 moderate, 1 low)	0
backend	13 (8 high, 4 moderate, 1 low)	0

The assessment listed 19 for the front end. The back end carried a further 13 that had not been counted; both trees are now clear. This included the DOMPurify advisory the assessment flagged as especially relevant given the application’s reliance on it.

nodemailer required a major bump (8 → 9.0.5) for GHSA-p6gq-j5cr-w38f, where a message-level raw option bypasses disableFileAccess / disableUrlAccess. The application was checked and never passes the raw option, so it was not exploitable through this path; it was upgraded regardless, and sendMail re-verified on the new major version.

RECOMMENDED NEXT
Enable Dependabot, or add npm audit to CI, so regressions surface automatically rather than at the next assessment.

9. AI-03 — Personal Data in Raw AI Response Blocks

SEVERITY	LOW — CVSS 5.3
CATEGORY	A01:2021 Broken Access Control · CWE-200
STATUS	Fixed

WHAT WAS WRONG
/api/ai/chat (optional authentication) returned owner_name and pet_id inside mating_match and adoption blocks to any caller, authenticated or not. This is precisely what made F-14 exploitable with no account at all — the assessment correctly identified the two as a chain.

WHAT WAS DONE

- owner_name — removed entirely. It is personal data the UI never rendered.
- pet_id — returned only to signed-in callers. The propose-match action needs it and already requires a login, so the feature is preserved while anonymous UUID harvesting is closed.

VERIFICATION

```
ANONYMOUS fields: name, species, breed, age_years, gender, bio, location,
avatar_url
owner_name: false | pet_id: false

SIGNED IN fields: pet_id, name, species, breed, age_years, gender, bio,
location, avatar_url
owner_name: false | pet_id: true
```

The chain is now broken at both ends: even where a pet_id is legitimately obtained, F-14 prevents it from yielding owner PII.

10. Regression Evidence

The full suite was run after every change, so the fixes are known not to have broken existing behaviour.

```
shopSlug : 50 passed, 0 failed
csvImport : 48 passed, 0 failed
AI eval : 141 passed, 0 failed, 3 skipped
frontend : build succeeded
backend : all modules load; email send re-verified on nodemailer 9.0.5
```

11. Outstanding Actions

Item	Owner	Why it was not automated
Rotate the Supabase database password	Repository owner	Credential operation in the Supabase dashboard
Purge git history and force-push	Repository owner	Rewrites shared history; invalidates every existing clone
Move the application off the postgres super-user to a scoped role	Repository owner	Requires provisioning a new database role
Enable Dependabot / npm audit in CI	Repository owner	Repository settings

Until the first two are complete, F-10 should be considered mitigated in code but not closed.

Prepared for the PetPluse project. All verification output reproduced in this report was captured from the running application and live database at the time of remediation.